D02 API Test Environment

D02 — API test environment and functional captures

Branch: `cursor/d02-backend-cicd-38d2`
Purpose: Portal evidence item 2 — access to the API/test environment + functional captures
Production: not redeployed for D02

Safety rule: Never put production secrets, real user credentials, private tokens, or live JWTs in source files, screenshots, or submitted evidence.

1. Verified test environments

A. Local disposable API harness — implemented & verified

Prerequisites: Node 24+, local PostgreSQL with a privileged admin able to create roles/databases (e.g. the OS `postgres` role). The **application** role created for tests is **not** a SUPERUSER.

```
        # 1) Create disposable role + DB + gitignored credentials
        chmod +x scripts/d02-setup-local-db.sh
        ./scripts/d02-setup-local-db.sh
        # Writes .env.d02.local (gitignored) with DATABASE_URL and
AUTH_JWT_SECRET.
        # Placeholders conceptually:
        #   DATABASE_URL=postgresql://grpd_d02_local:
<LOCAL_ONLY_PASSWORD>@127.0.0.1:5432/grpd_d02_local
        #   AUTH_JWT_SECRET=<LOCAL_ONLY_JWT_SECRET>

        # 2) Load local-only env (do not paste values into PDFs)
        set -a; source .env.d02.local; set +a

        # 3) Migrate + verify
        npx prisma generate
        npx prisma migrate deploy
        npm run test:d02 -- --ci
        npx tsx scripts/d02-evidence-capture.ts
```

Privileges used by the app role: `LOGIN` owner of its disposable database (`NOSUPERUSER`, `NOCREATEDB`, `NOCREATEROLE`). Migrations run as that owner against its own DB.

Artifacts under `docs/funding/technical-evidence/D02/evidence/`:

File	Content
`functional-captures.json`	Sanitized request/response transcript
`d02-integration.txt`	Jest D02 suite output
`unit-tests.txt`	Unit suite output
`typecheck-server.txt`	Server TypeScript check
`migrations.txt`	`prisma migrate deploy` transcript

B. CI (GitHub Actions) — implemented & verified

Workflow: `.github/workflows/backend-verification.yml`

- Postgres 14 service on port `55439`
- `prisma migrate deploy`, unit tests, `typecheck:server`, `npm run test:d02`
- Uploads `d02-ci-results/` as a workflow artifact
- Confirmed green on this branch (commit `6bebba4` and later fixes on the same PR)

CI uses workflow-scoped synthetic secrets. Those values are **not** reproduced in this PDF.

C. Hosted Vercel Preview — future option only (not D02 verification)

- A Preview build may appear when the PR is pushed.
- Exercising authenticated API calls on Preview would require configuring Preview-only `DATABASE_URL` (e.g. a Neon test branch) and a synthetic `AUTH_JWT_SECRET` in the Vercel dashboard.
- **This pack does not claim** that Preview env vars were configured or that hosted Preview journeys were used as acceptance evidence.
- Authoritative functional proof for D02 remains **local disposable Postgres + CI**.

D. Production — unchanged

Existing production (`grpd30.vercel.app` / Neon production) was **not** redeployed as part of D02.

2. Functional captures (real, sanitized)

Source of truth: `evidence/functional-captures.json`
`capturedAt`: `2026-11-09T18:56:15.470Z`
Environment note in artifact: local disposable PostgreSQL; tokens/passwords redacted.

Results table

Step	Method	Path	Expected	Cap sta
1 Health	`GET`	`/api/v1/health`	200, `database: ready`	**200**
2 Register	`POST`	`/api/v1/auth/email/register`	200 + user + tokens	**200**
3 Unauthenticated	`GET`	`/api/v1/me/memberships` (no Bearer)	401 `UNAUTHORIZED`	**401**
4 Create club	`POST`	`/api/v1/clubs` (admin Bearer)	200 club	**200**
5 Invite	`POST`	`/api/v1/clubs/:id/invite` (admin)	200 invite code	**200**
6 Join	`POST`	`/api/v1/clubs/join-by-code` (member)	200 membership	**200**
7 Role deny	`GET`	`/api/v1/clubs/:id/roster` (member)	403 `FORBIDDEN`	**403**
8 Role allow	`GET`	`/api/v1/clubs/:id/roster` (admin)	200 members list	**200**

All eight assertions in the capture file are `true`.

Excerpt — unauthenticated rejection (sanitized)


```
        {
          "step": "3_unauth_me",
          "method": "GET",
          "path": "/api/v1/me/memberships",
          "status": 401,
          "requestNotes": "No Authorization header → expect 401
UNAUTHORIZED",
          "response": {
            "ok": false,
            "error": { "message": "Unauthorized", "code":
"UNAUTHORIZED" }
          }
        }
```


Excerpt — role deny (member → roster)


```
        {
          "step": "7_roster_member_forbidden",
          "method": "GET",
          "path": "/api/v1/clubs/<clubId>/roster",
          "status": 403,
          "response": {
```

```
            "ok": false,
            "error": { "message": "Forbidden", "code": "FORBIDDEN" }
          }
        }
```


Excerpt — role allow (admin → roster)


```
        {
          "step": "8_roster_admin_ok",
          "method": "GET",
          "path": "/api/v1/clubs/<clubId>/roster",
          "status": 200,
          "response": {
            "ok": true,
            "data": {
              "clubId": "<clubId>",
              "members": [
                { "userId": "d02_evidence_admin", "role": "admin",
"status": "approved" },
                { "userId": "d02_evidence_member", "role": "member",
"status": "approved" }
              ]
            }
          }
        }
```


(Full sanitized bodies, including register/create/invite/join, are in `evidence/functional-captures.json`. Invite codes and JWTs are either fixture data or redacted.)

3. Commands and results executed for this pack

```
npx prisma migrate deploy              → 6 migrations applied
(evidence/migrations.txt)
npm test -- --ci                       → 7 suites / 69 passed
(evidence/unit-tests.txt)
npm run typecheck:server               → exit 0
(evidence/typecheck-server.txt)
npm run test:d02 -- --ci               → 2 suites / 11 passed
(evidence/d02-integration.txt)
npx tsx scripts/d02-evidence-capture.ts → 8/8 assertions true
(evidence/functional-captures.json)
GitHub Actions Backend verification    → success on branch tip  (see
PR checks)
```

4. Auth path exercised by captures

- **Active:** email register → app HS256 Bearer JWT → protected club routes + roster AuthZ.

- **Not exercised / not claimed:** Supabase JWT verification (`lib/server/supabase-jwt.ts` remains inactive without `SUPABASE_*` env).
- **Optional fixture only:** `POST /api/v1/auth/pin/login` when `PIN_ALLOWLIST_JSON` is set (not required for the captures above).

5. Limitations

- Local credentials live only in `.env.d02.local` (gitignored) or CI secrets; they must not be copied into PDFs.
- Hosted Preview is a **future** option until Preview env vars are deliberately configured; it is not the D02 acceptance environment in this pack.
- Production remains untouched.